Product readiness diagnostic (offline version)

Forty statements in ten domains score each product family from 0 to 4. The target is level 3 on every statement by 11 Dec 2027, and on Article 14 reporting now; the moderated baseline on 28 Oct 2026 was 44%. Question IDs match the live CRA Readiness Diagnostic (D08), so offline scores load into it without mapping.

How to run it

One record per product family is scored by the people who hold the evidence and moderated by the programme; only moderated scores enter the index.

1. **Self-score (12–15 minutes).** The product owner, lead engineer and PSIRT or quality contact score the 40 statements together and cite evidence for every level 3 or 4.
2. **Moderate (60–90 minutes).** The moderation panel tests each claim against its evidence and agrees the score; every change is logged with a reason.
3. **Load.** The moderated record goes into the live CRA Readiness Diagnostic (D08), which uses the same IDs, or into the system of record as an offline file.
4. **Act.** The five lowest-scoring statements become the family's priority actions, taken from the action column.

Where SKUs in a family differ in architecture or update mechanism, score the weakest SKU and note the difference.

Record field	Format	Example (illustrative)
Family	ID and name from the scope register	T200 Smart Thermostat
Business unit	HBS, IC or S&S	HBS
CRA class	Default, Class I, Class II or critical; flag provisional decisions	Default
Wave	Wave 1, 2 or 3	Wave 1 (pilot)
Conformity route	Module A, B+C or H	Module A
Respondents	Roles; names optional	Product owner; lead engineer; PSIRT analyst
Moderators	Roles	Compliance lead; product security officer
Dates	Self-scored; moderated	[date]; [date]

Record field	Format	Example (illustrative)
Instrument version	Version and facts date	v1.0, facts as at 30 Oct 2026

Answer format, identical for all 40 statements:

- **Score:** single choice, required: 0 Not started, 1 Initial, 2 Defined, 3 Implemented, 4 Assured.
- **Evidence reference:** text or link, required at level 3 or 4, optional below.
- **Notes:** free text, optional.
- **No "not applicable" option.** Where a statement's condition cannot arise for the family, such as a pre-assessment (Q10.2) for a Module A family, a recorded and evidenced decision that it does not arise scores level 3.

Instruction to paste at the top of the form:

> Score what exists today for this product family, not what is planned. Without evidence you can show, score no higher than 2. Do not enter details of unfixed vulnerabilities.

Scale

Level 3 is the target: practice applied consistently for this product, with evidence. Level 4 adds measurement and independent review, but scores above 3 do not raise the readiness index.

Level	Name	Descriptor	Evidence the moderator expects
0	Not started	Nothing exists yet.	None
1	Initial	Ad hoc or individual effort; not documented.	A named person can describe the practice; no approved document
2	Defined	Documented and partly applied; gaps known.	An approved procedure or template, and a written list of known gaps

Level	Name	Descriptor	Evidence the moderator expects
3	Implemented	Applied consistently for this product, with evidence.	Records for this product from the latest release or cycle, retrievable from the system of record
4	Assured	Measured, independently reviewed and audit-ready.	Level 3 records plus metrics and a review by the second line, internal audit or a third party within the last 12 months

Questions D1 to D5

Twenty statements cover how the product is governed, scoped, designed, built and supplied; SBOM and supply chain is the weakest of the five at 38%.

D1 · Governance and accountability

Baseline 28 Oct 2026: average level 1.75, readiness 58%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q1.1	A named executive is accountable for CRA compliance, with written authority to block a release and to sign EU declarations of conformity.	Art 13(1); Art 28(4)	Board or ExCo instrument naming the accountable executive and the DoC signatory	Execute a signing instrument naming the DoC signatory, alternate and scope; write release-blocking authority into the sponsor's mandate.
Q1.2	The core CRA roles (compliance lead, product security officer, PSIRT lead) are filled by named people with deputies.	Art 13; BSI TR-03183-3 s4.3	Role descriptions, appointments, deputy chain	Appoint named role holders and deputies; publish the RACI with one accountable person per decision.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q1.3	A written product-risk acceptance rule excludes cost, risk appetite and commercial strategy as reasons to leave risk unaddressed.	Annex I Part I(1); guidance C(2026) 5252 paras 156-163	Risk policy section for the product-risk category; acceptance log	Add a product-risk category to the enterprise risk framework with its own acceptance authority and a non-cost appeal route.
Q1.4	A programme board reviews CRA readiness monthly against KPIs drawn from a system of record.	Good practice; Annex VIII Module H pt 3.2	Programme board minutes; KPI pack	Run a monthly programme board with a standing agenda and KPIs read from the system of record.

D2 · Scope, inventory and classification

Baseline 28 Oct 2026: average level 1.35, readiness 45%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q2.1	Every product, version, variant, companion app and backend is in a register with a recorded scope decision.	Art 2(1); Art 3(1); guidance paras 11-16	Scope register extract; decision records	Build the register from release, commercial and cloud systems, then record a dated scope decision per row.
Q2.2	Remote data processing boundaries are mapped per product function using the three-element test.	Art 3(2); guidance paras 184-205	Remote-function map per product	Map every remote function to its service, developer and fallback; classify each as RDPS, component or out of scope.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q2.3	Each product has a documented class (default, Class I, Class II or critical) with a core-functionality rationale.	Arts 7-8; Annexes III-IV; Implementing Regulation (EU) 2025/2392	Classification decision record citing the technical description	Classify on core functionality against the Implementing Regulation's technical descriptions; take legal review on borderline cases.
Q2.4	The economic-operator role per market and the legacy status of each product line are recorded.	Arts 18-22; Art 69(2)-(3)	Role-per-market table; legacy flags in the register	Record manufacturer, importer, distributor or representative per market; flag lines still sold after 11 Dec 2027.

D3 · Risk assessment and secure by design

Baseline 28 Oct 2026: average level 1.40, readiness 47%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q3.1	A documented cybersecurity risk assessment exists for the product or family, covering intended purpose, foreseeable use and expected time in use.	Art 13(2)-(3); Annex VII point 3	Signed risk assessment	Run a TR-03183-1-style assessment on the representative product and sign it off through the second line.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q3.2	The assessment states whether and how each Annex I Part I(2)(a)-(m) item applies, with a justification for every item marked not applicable.	Art 13(3)-(4); Recital 55	Applicability matrix with justifications	Complete the 13-row applicability matrix; no row may be signed with a blank justification.
Q3.3	Threat models and data-flow diagrams are maintained and updated on defined triggers, not on a calendar.	Art 13(3); Annex I Part II(3); guidance paras 238-240	Threat model versions with change log	Wire update triggers (security-relevant release, new vulnerability, new threat) into the release and PSIRT processes.
Q3.4	Secure-by-default configuration (no default credentials, minimal exposed services, reset to original state) is verified at every release.	Annex I Part I(2)(b), (j)	Default-configuration export; reset test record	Add a secure-default configuration check and a reset test to the release gate.

D4 · Secure development and testing

Baseline 28 Oct 2026: average level 1.67, readiness 56%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q4.1	A documented secure development lifecycle with a release security gate applies to every release.	Annex I Part I(1); Annex VIII Module H pt 3.2	SDLC procedure; release gate records	Define the release security gate and make its signed record a precondition for tagging a release.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q4.2	Every release is checked for known exploitable vulnerabilities against EUVD, NVD and the CISA KEV catalogue before it ships.	Annex I Part I(2)(a); guidance paras 230-237	Scan reports and VEX tied to the release SBOM	Automate a known-exploitable check that blocks the release unless each finding is fixed or carries a VEX justification.
Q4.3	Security testing (static analysis, fuzzing, dynamic testing, penetration tests) is risk-driven and evidenced per release.	Annex I Part II(3); Annex VII point 6	Test plan with review log; test reports	Write a threat-driven test plan per product and keep a dated review log showing what was re-tested and why.
Q4.4	Each release records a substantial-modification decision using the four-question test.	Art 3(30); guidance paras 103-124	Security-delta assessment on the gate record	Add the four guidance questions to the release gate and route positive answers to a new declaration.

D5 · Supply chain, SBOM and open source

Baseline 28 Oct 2026: average level 1.13, readiness 38%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q5.1	A machine-readable SBOM (CycloneDX 1.6+ or SPDX 3.0.1+) is generated from the shipped artefact for every release.	Annex I Part II(1); Annex VII point 2(b); BSI TR-03183-2	Signed SBOM per release with quality score	Generate SBOMs at build from the artefact, enrich to TR-03183-2 fields, sign and store them with the release.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q5.2	Third-party and open-source components pass a documented due-diligence gate before use.	Art 13(5); Recital 34; guidance paras 167-173	Component intake records	Run an intake gate on every new dependency recording need, maintenance signals, licence, vulnerability history and exit plan.
Q5.3	Supplier contracts require vulnerability notification, SBOM delivery and support-period commitments.	Art 13(5), (8); Art 23	Contract clause register	Add the CRA clause pack to master agreements, starting with suppliers of security-relevant components.
Q5.4	Vulnerabilities found in components are reported upstream and fixes are shared with maintainers.	Art 13(6); guidance paras 222-229	Upstream report log in PSIRT case files	Give PSIRT or the OSPO ownership of upstream reporting, with a duplicate check and legal pre-clearance for fix sharing.

Questions D6 to D10

Twenty statements cover how the product is maintained, reported, documented and brought to market; Article 14 reporting is the strongest domain at 72% and conformity and market access the weakest at 16%.

D6 · Vulnerability handling and disclosure

Baseline 28 Oct 2026: average level 1.15, readiness 38%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q6.1	A coordinated vulnerability disclosure policy, a security.txt file and a non-automated contact channel are published.	Annex I Part II(5)-(6); Art 13(17)	Published CVD policy URL; security.txt; intake monitoring log	Publish the CVD policy and security.txt, add an anonymous web form and a monitored human channel.
Q6.2	A PSIRT triages every report and monitoring hit for severity, reachability and active exploitation.	Annex I Part II(2); Art 14(1)	PSIRT procedure; case files with UTC timestamps	Open a case for every report and hit; record reachability and the exploitation decision in UTC.
Q6.3	Fixed vulnerabilities are disclosed in public advisories, machine-readable where appropriate, with VEX for non-affected findings.	Annex I Part II(4); BSI TR-03183-3	Advisory index; CSAF documents; VEX files	Stand up an advisory page and a CSAF provider; publish VEX statements for findings that do not affect the product.
Q6.4	Vulnerability case records are retained and response metrics are reported.	Art 13(7), (13)	Quarterly PSIRT metrics; retention rule	Report acknowledgement and fix times quarterly and retain case files for 10 years or the support period.

D7 · Updates and support period

Baseline 28 Oct 2026: average level 1.44, readiness 48%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q7.1	Updates are signed, verified before install, protected against rollback and recoverable after a failed install.	Annex I Part I(2)(c), (f); Annex I Part II(7)	Update design note; acceptance tests	Move signing keys into an HSM, add anti-rollback counters and atomic install with recovery.
Q7.2	Security updates install automatically by default where applicable, with user notification and a clear opt-out.	Annex I Part I(2)(c); Recital 56	Default configuration export; Annex II point 8(e) text	Turn automatic security updates on by default, or record the Recital 56 carve-out in the risk assessment.
Q7.3	Security fixes can ship separately from feature releases and remain available for at least 10 years.	Annex I Part II(2), (8); Art 13(9)	Maintenance branch policy; update repository retention	Run security-only maintenance branches and an immutable update repository retained for 10 years.
Q7.4	A support period is set per product from expected time in use, and the end date is shown at purchase.	Art 13(8), (19); Annex II point 7	Support-period determination record; product page	Determine the support period from expected use time (five years is a floor) and publish the end month and year.

D8 · Article 14 reporting readiness

Baseline 28 Oct 2026: average level 2.15, readiness 72%. Reporting has applied since 11 Sep 2026, so this domain's target is level 3 now.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q8.1	At least two Assigned Representatives are registered on the ENISA Single Reporting Platform with MFA, and the coordinator CSIRT is decided.	Art 14(7); ENISA SRP FAQ 9, 18	SRP roster; coordinator CSIRT decision record	Register two or more personal EU Logins with MFA and record the main-establishment decision before any incident.
Q8.2	Written awareness criteria and a 24/7 on-call chain allow an early warning to be filed within 24 hours, including at weekends.	Art 14(2)(a), (4)(a); guidance para 213	PSIRT runbook; on-call rota; deputy chain	Write the awareness test into the runbook and give the PSIRT lead and deputies authority to file without prior approval.
Q8.3	Templates for the 24-hour, 72-hour and final reports and for user notification exist and have been rehearsed.	Art 14(2)-(4), (8); ENISA SRP glossary	Templates; drill records	Draft templates on the SRP glossary fields and run two paper drills a year, one vulnerability and one incident.
Q8.4	Legacy and end-of-support products are included in the reportable inventory.	Art 69(3); guidance para 210	Reportable inventory including legacy lines	Add every in-scope product still in use to the reportable inventory, including lines no longer sold or supported.

D9 · Documentation, user information and declaration

Baseline 28 Oct 2026: average level 0.73, readiness 24%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q9.1	An Annex VII technical file exists for each product version and is versioned with releases.	Art 31; Art 13(12)-(13); Annex VII	Technical file index per version	Adopt the 13-part file outline and generate version-linked contents from the release pipeline.
Q9.2	Annex II user information, including the support end date and the vulnerability contact, is drafted and ready to publish.	Art 13(18)-(19); Annex II	Annex II document per product	Draft the Annex II document per product family and publish it at a stable, versioned URL.
Q9.3	The EU declaration of conformity format, signing authority and CE marking placement are decided.	Arts 28-30; Annexes V-VI	DoC template; signing instrument; CE placement record	Agree the DoC template and languages, the signing instrument and where the CE marking sits for hardware and software.
Q9.4	Evidence sits in a system of record with 10-year retention and can answer a reasoned request within 10 working days.	Art 13(13), (22); Art 64(4)	System of record; tested request export	Select a system of record, compute retention per version and test an end-to-end reasoned-request export.

D10 · Conformity assessment and market access

Baseline 28 Oct 2026: average level 0.48, readiness 16%.

ID	Statement	Legal basis	Evidence to attach	Action if below level 3
Q10.1	The conformity route for the product (Module A, B+C or H) is decided, with a fallback.	Art 32; Annex VIII	Route decision record	Decide the route per family; for Class I, plan third-party assessment until a harmonised standard is cited.
Q10.2	Candidate notified bodies are shortlisted and a pre-assessment is contracted where the route needs one.	Art 32(2)-(3); Arts 35-43	Shortlist; pre-assessment contract	Shortlist three candidates, contract pre-assessments with conversion options, and check NANDO at every programme board.
Q10.3	A complete Module A internal-control record is kept for the product, even where a notified body will be used.	Annex VIII Module A	Internal-control record with evidence index	Build the Module A record and evidence index now; it is the fallback and the body's application pack.
Q10.4	EU representation, importer and distributor duties and marketplace arrangements are settled for each market.	Arts 18-20; Regulation (EU) 2019/1020 Art 4	Representation decision per market; mandates	Confirm the role per market, appoint an authorised representative where useful and brief importers on their checks.

Scoring rules

The readiness index measures how much of the way to level 3 a family has come; scores above 3 are capped so that assurance in one area cannot hide a gap in another.

$$\text{RI} = \frac{1}{n}\sum_{i=1}^{n}\frac{\min(s_i,\,3)}{3}$$

- **Terms.** s_i is the moderated score of statement i (0 to 4); n is 40 for a family and 4 for a domain.

- **Average level.** The plain mean of the raw scores, shown in heatmaps to two decimals; it is not capped.
- **Roll-ups.** Portfolio, BU and class indices are unweighted means of the family indices, so every family counts once whatever its revenue.
- **Rounding.** Indices are reported as whole percentages and average levels to two decimals; inputs are never rounded before computing.
- **Worked example.** T200 Smart Thermostat at baseline: its 40 capped scores sum to 55, and 55 ÷ (40 × 3) = 45.8%, reported as 46%.
- **Completeness.** A record enters the index only when all 40 statements are scored.
- **Self versus moderated.** Both scores are kept; only the moderated score enters the index and K01.

Moderation

Self-scores are tested against evidence, not opinion: without evidence there is no level 3.

Panel. The compliance lead and the product security officer moderate every family; the PSIRT lead joins for D6 and D8, and the Head of quality & regulatory for D9 and D10. The same panel moderates all 13 families, starting with the T200 pilot to calibrate.

1. **Evidence for level 3.** A level 3 or 4 needs the evidence named in the "Evidence to attach" column, opened from the system of record during the session. Missing evidence caps the score at 2.
2. **Evidence for level 4.** Level 4 also needs metrics and an independent review (second line, internal audit or a third party) dated within the last 12 months.
3. **Group capabilities.** Capabilities run once for the group, such as governance (D1) and SRP registration (Q8.1), take one moderated score for every family unless a family deviates. This is why D1 sits at 1.75 for all 13 families in the baseline.
4. **Consistency with programme facts.** A score must agree with what the programme measures elsewhere. As at 30 Oct 2026:
   - Q5.1 at level 3 needs signed SBOMs on the family's releases; only 9 of 24 releases in the last 30 days had one (K07).
   - Q10.2 at level 3 needs a contracted pre-assessment; none is contracted yet, with 3 candidates shortlisted and 1 proposal received (K12).
   - Q8.1 at level 3 matches the 3 Assigned Representatives registered on the SRP (K04).
   - Q9.4 above level 1 needs a selected system of record; the selection is pending (WS6).

5. **Challenge questions.** "Show me the record for the last release." "Who does this when the owner is away, and where is that written down?" "What happened the last time this was tested, and what changed?" "Which SKUs in the family does this not yet cover?"
6. **Under-scoring check.** At least one statement per domain scored 0 to 2 is checked for evidence the team overlooked; Industrial Connectivity families with IEC 62443-4-1 records are the likeliest case.
7. **Disagreement.** The moderated score stands. The self-score and the reason for the change are logged, and the average gap between self and moderated scores is reported as a calibration measure.
8. **Time box.** 60 to 90 minutes per family; an open item gets an owner and a date, never a provisional score.

Targets and cadence

Every family reaches level 3 on every statement by 11 Dec 2027, and on Article 14 reporting now, because reporting has applied since 11 Sep 2026.

Measure	Baseline, 28 Oct 2026	Target	By
Portfolio readiness index (K01)	44%	70%	Jun 2027
Portfolio readiness index (K01)	44%	90%	Nov 2027
Statements at level 3 or above, all families	21 of 520 (4%)	520 of 520	11 Dec 2027
Art 14 reporting domain (D8)	72%	100%	Now

- **Monthly.** Product teams update their record in the live CRA Readiness Diagnostic (D08) before each programme board; K01 reads from it.
- **Quarterly.** The panel re-moderates every family in Mar, Jun and Sep 2027, checking the evidence behind every level 3 and 4 claim.
- **On a trigger.** A new family, a substantial modification or a classification change re-opens the record; the legal opinion on EG-700 and HomeHub H3, due 27 Nov 2026, is the first such trigger.
- **Plan check.** Each month's index is compared with the plan trajectory in tab 8. The plan reaches 91% in Nov 2027 and 93% in Dec 2027, so any statement still below level 3 when declarations are signed (M13, 3 Dec 2027) needs a recorded decision before signature.

Project Rampart · Survey and Interview Instruments (D07) · Illustrative · 31 Oct 2026